

This document presents a PCI DSS audit plan for SnowBe Online based on a structured audit planning approach. It outlines how the audit will evaluate the company's ability to protect cardholder data across its AWS-hosted systems and on-premises infrastructure. The audit plan focuses on key risk areas such as access control, data storage, and system vulnerabilities to ensure alignment with PCI DSS compliance requirements.

Audit Plan

Group 1

Kayla Hodge
Mark VanDike
Justin Vandrunen
Jarred Ward
Jordan Wicks

1. Document the steps you will take to complete a generic audit plan.

1) Define audit objectives and scope

The first step is to define what the audit is trying to accomplish and what areas will be reviewed. This includes setting goals such as evaluating compliance, identifying risks, and assessing control adequacy and effectiveness. When establishing the scope, it is also important to consider known threats and vulnerabilities, so the audit focuses on areas with higher risk. Establishing both the objectives and scope together ensures the audit is aligned with expectations and avoids unnecessary scope creep.

2) Conduct audit interviews

Next, identify key employees across different levels of the organization who will be involved in the audit. This typically includes management, IT staff, and end users who interact with systems daily. Questions should be prepared in advance and tailored to each role, so responses are meaningful and relevant. These interviews help confirm how processes work and may reveal issues that are not documented.

3) Refine the scope

After gathering initial information, the scope should be reviewed and adjusted if needed. This step allows the audit team to shift focus toward higher-risk areas based on what was learned from interviews and early analysis. Known threats and vulnerabilities can be used here to prioritize systems or processes that require deeper review.

4) Assemble the audit team

The audit team should be assembled based on the skills required for the audit. This includes ensuring there are individuals who can cover key IT domains such as user systems, networks, and applications. Each team member should have clearly defined responsibilities to avoid confusion and overlap. Assigning the right expertise to the right areas helps ensure a more effective audit.

5) Establish milestones and timeframes

At this stage, key milestones and deadlines should be established for the planning process. This includes scheduling interviews, completing documentation reviews, and setting a clear timeline for when the audit will begin. Having defined timeframes helps keep the team accountable and ensures steady progress. It also makes it easier to manage expectations and avoid delays.

6) Flowcharting

Flowcharting is used to visually map out systems and processes, so they are easier to understand. These diagrams show how data moves through the organization and where controls are applied. This step is especially useful for identifying gaps, inefficiencies, or weak points in a process. It also helps the audit team quickly understand complex workflows.

7) Select and configure audit tools

The final step is selecting and preparing the tools that will be used during the audit. This can include checklists, templates, risk assessment tools, and compliance frameworks. Having these tools ready ahead of time helps improve consistency and efficiency once the audit begins. It also ensures the team is fully prepared to move into the audit phase without delays.

2. How would you conduct an interview as you prepare for a PCI DSS audit for the fictitious company?

a) How would you begin the interview?

I would begin the interview by introducing myself, explaining my role, and clearly stating the purpose of the audit in a way that reduces anxiety. It is important to make it clear that the goal is to understand processes and improve security, not to single out individuals or assign blame. I would use a brief icebreaker related to the employee's role or environment to build rapport and make the interaction feel more natural. I would then set expectations by outlining what topics will be discussed and how long the interview will take, while also explaining that I will be taking notes to accurately capture information for reporting purposes. I would clarify that note-taking is a standard part of the audit process and is not a reflection of anything they said or did, but simply to ensure nothing is missed. This approach helps establish trust, encourages honest responses, and sets a professional but approachable tone for the rest of the interview.

b) What questions would you ask and to what level of employee?

The questions in this section are designed to gather information from multiple levels within SnowBe Online to understand how PCI DSS controls are implemented and followed in practice. Each group is asked questions that match their role, with executives focusing on oversight, managers on enforcement, IT staff on technical controls, and end users on daily operations. The questions are open-ended and structured to encourage honest responses without leading the interviewee. This approach helps identify gaps between policy and actual behavior and provides a clearer picture of how security controls function across the organization.

Operational / End Users (Cashiers, Customer Support, Sales Staff):

At this level, the focus is on day-to-day behavior and actual processes. These questions help identify gaps between policy and real-world practice.

Questions:

- Can you walk me through how you process a credit card transaction?
- Do you ever see or handle full credit card numbers?
- What would you do if you suspected a security issue?
- How often do you receive training on handling customer data?
- Are there any challenges you face when following security procedures?

IT / Technical Staff (System Administrators, Network Engineers, AWS Administrators):

For IT and security staff, the focus shifts to how controls are implemented and maintained. These questions help determine whether technical safeguards align with PCI DSS requirements.

Questions:

- How is cardholder data stored, encrypted, and protected?
- What access controls are in place to restrict sensitive data?
- How are systems patched and kept up to date?
- What tools are used to monitor systems and detect suspicious activity?
- How are security incidents identified and handled?

Mid-Level Employees (Store Managers, Department Supervisors):

At this level, the focus is on how policies and procedures are enforced in daily operations. Managers provide insight into how expectations from leadership are carried out in practice.

Questions:

- How do you ensure employees follow PCI DSS procedures?
- How do you monitor employee access to sensitive data?
- What steps do you take when a policy violation occurs?
- How do you verify that employees complete required security training?
- What challenges do you face when enforcing security policies?

Senior Management / Executives (CIO, CFO, CEO):

At this level, the focus is on governance, oversight, and accountability rather than technical detail. The goal is to understand how leadership ensures compliance and supports security across the organization.

Questions:

- How does the organization ensure PCI DSS compliance across all departments?
- What policies are in place to protect cardholder data?
- How is risk related to payment processing identified and managed?
- How often are security policies reviewed and updated?
- How are employees held accountable for following security policies?

c) How would you end the interview?

I would end the interview by thanking the individual for their time and acknowledging that their input is valuable to the audit process. I would briefly summarize key points or clarify anything that may need confirmation to ensure accuracy. I would then ask for the best way to contact them if follow-up questions are needed later. Ending the interview in a respectful and appreciative way helps maintain trust and encourages continued cooperation. If appropriate, I would also close with a brief personal or situational comment similar to the opening to keep the interaction consistent and professional.

3. Based on the steps from question 1, design a PCI DSS audit plan for SnowBe Online.

This PCI DSS audit plan is designed specifically for SnowBe Online and applies the structured audit planning steps to its environment. It focuses on evaluating how SnowBe protects cardholder data across its AWS-hosted systems, on-premises servers, and payment processes. The plan also prioritizes SnowBe's key risk areas, including excessive access, outdated systems, and long-term data storage, to ensure the audit is focused and effective.

1) Define audit objectives and scope

The objective of the PCI DSS audit is to determine whether SnowBe Online is compliant with PCI DSS requirements and whether its controls are both adequate and effective. The scope will focus on all systems that store, process, or transmit cardholder data within SnowBe's environment. This includes:

- AWS-hosted e-commerce website and databases
- On-premises servers (access management, CRM, accounting, vendor systems)
- Online payment processing systems (website transactions)
- In-store payment systems (bank-provided credit card terminals)
- Employee endpoints (desktops and VPN-connected laptops)

Key PCI-specific considerations:

- SnowBe processes approximately 1.2 million transactions annually, placing it in a higher PCI merchant level
- Identification of the appropriate SAQ type or reporting requirement
- Review of network segmentation, encryption, and firewall configurations
- Focus on known risks such as broad access permissions and indefinite data storage

2) Conduct audit interviews

Audit interviews are conducted to understand how PCI DSS controls are implemented and followed across SnowBe's environment. This step allows the audit team to gather information directly from employees at different levels to see how security policies are applied in real-world situations. It also helps compare documented procedures with actual behavior, which is critical since gaps often exist between what is written and what is practiced. By asking role-specific, open-ended questions and observing responses, the audit team can identify weaknesses, inconsistencies, or misunderstandings that may impact PCI compliance:

Operational / End Users

- How credit card transactions are processed (online and in-store)
- Exposure to cardholder data
- Security awareness and training practices

IT / Security Staff

- Storage, encryption, and protection of cardholder data
- Patch management and system updates
- Monitoring tools, logging, and incident response

Manager / Supervisor

- Enforcement of PCI procedures in daily operations
- Monitoring of employee access and behavior
- Handling of policy violations

Executive / Management

- PCI compliance oversight and strategy
- Security policies related to cardholder data
- Risk management and reporting practices

3) Refine the scope

After gathering initial information, the audit scope is reviewed and adjusted to focus on the areas that present the highest risk to SnowBe's PCI compliance. This step ensures that time and resources are directed toward systems and processes that have the greatest potential impact:

- Access control weaknesses (most employees having access to multiple systems)
- Cardholder data storage practices (data stored indefinitely)
- Unpatched systems and outdated software (Windows systems and WordPress platform)
- Website vulnerabilities (WordPress shopping cart risks)
- Lack of monitoring or alerting for failed attack attempts

4) Assemble the audit team

The audit team is assembled based on the skills and expertise needed to evaluate SnowBe's technical environment and PCI requirements. This step ensures that each area of the audit is supported by individuals with the appropriate knowledge and experience:

Network Security Specialist

- Firewalls
- Segmentation
- VPN access
- network traffic

Systems / Application Specialist

- AWS environment
- Servers
- CRM
- Order management systems

Endpoint / User Domain Specialist

- Desktops
- Laptops
- user access
- endpoint security

Audit Lead

- Oversees audit progress
- Ensures PCI DSS coverage
- manages reporting

5) Establish milestones and timeframes

Milestones and timeframes are established to organize the audit planning process and ensure it stays on schedule. This step helps manage expectations, control costs, and ensure all planning activities are completed before the audit begins:

Planning Phase (Weeks 1–4)

- Define objectives and scope
- Conduct interviews across SnowBe
- Refine scope based on findings
- Assemble audit team
- Develop flowcharts and select tools

Preparation Phase (Weeks 5-6)

- Review SnowBe documentation (security policies, configurations, prior findings)
- Analyze consultant recommendations (patching, access control, server security)
- Validate readiness of systems and audit tools
- Finalize audit scope and confirm logistics

Audit Readiness Milestones

- All interviews completed
- Scope finalized and approved
- Audit team fully assigned
- Tools configured and tested
- CDE and key systems identified and mapped

Clear timeframes will help control cost, maintain efficiency, and ensure the audit begins on schedule.

6) Flowcharting

Flowcharting is used to visually map SnowBe's systems and processes, making it easier to understand how cardholder data moves through the environment. This step helps identify control points, gaps, and potential weaknesses that may impact PCI compliance:

Online payment data flow

- Identify where cardholder data is captured, transmitted, and stored
- Customer ➡ SnowBe website (AWS) ➡ payment processing ➡ data storage

In-store transaction flow

- Confirm that cardholder data is not improperly stored locally
- POS terminal ➡ bank processing ➡ internal systems

Access control flow

- Identify excessive access and lack of least privilege
- User login ➡ VPN ➡ system access ➡ privilege levels

Purpose of flowcharting:

- Identify where cardholder data is stored, processed, and transmitted
- Detect gaps in network segmentation or control placement
- Highlight weak or missing controls in SnowBe's environment
- Provide a clear visual reference for the audit team

7) Select and configure audit tools

Audit tools are selected and prepared to support the evaluation of SnowBe's PCI DSS compliance. This step ensures that the audit team has the necessary resources in place to efficiently collect data, validate controls, and document findings:

PCI DSS requirement checklist

- Ensures all required controls are reviewed and documented

External vulnerability scanning tools

- Required for PCI DSS to identify internet-facing vulnerabilities

Internal vulnerability scanning tools

- Identify weaknesses within SnowBe's internal network and systems

Configuration and compliance tools

- Review firewall rules, server configurations, and endpoint settings
- Validate removal of default credentials and proper system hardening

Log monitoring and SIEM tools

- Analyze access logs, detect anomalies, and verify monitoring controls

Encryption and data discovery tools

- Identify where cardholder data is stored
- Verify encryption is properly implemented

Additional considerations:

- Ensure tools align with PCI DSS requirements for SnowBe's merchant level
- Confirm all tools are properly configured before the audit begins
- Verify audit team members are trained on tool usage
- Use standardized templates to document findings consistently